

Asmita — Technical Requirements Document

Version: 0.1 (Draft) **Date:** 2026-05-12 **Status:** Pre-development **Derived from:** PRD_Asmita.md v0.2 (2026-05-11)

Table of Contents

1. Purpose, Scope & Conventions
 2. System Context & Architecture
 3. Functional Requirements
 - FR-REG: Registration & Verification
 - FR-URL: URL Submission
 - FR-NR: Notice Routing Engine
 - FR-ESC: Auto-Escalation Scheduler
 - FR-DASH: Case Tracking Dashboard
 - FR-SUP: Support & Resources
 - FR-MIN: Minor / POCSO Pathway
 - FR-ADMIN: Admin Panel
 4. Notice Routing State Machine
 5. Data Model
 6. API Specifications
 7. Authentication & Session Management
 8. Email Infrastructure
 9. Verification & Abuse-Prevention Pipeline
 10. Privacy & DPDP Technical Controls
 11. Audit Logging
 12. Internationalisation (i18n)
 13. Non-Functional Requirements
 14. Observability
 15. Infrastructure & Deployment
 16. Testing Strategy
 17. Phase 2 Forward Compatibility
 18. Deferred Decisions (from PRD §19)
-

1. Purpose, Scope & Conventions

1.1 Purpose

This TRD translates the Asmita PRD v0.2 into verifiable technical requirements for the engineering team. Every functional requirement carries an ID, acceptance criterion, and verification method. Non-functional requirements carry measurable targets.

1.2 Scope

Phase 1 only (Months 1–6): URL-based notice system. No client-side hashing, no hash database, no hash network partnerships. Phase 2 interfaces are identified but not designed here (see §17).

1.3 Requirement Levels

Per RFC 2119:

- **MUST / SHALL** — mandatory; failure is a blocker for launch
- **SHOULD** — strong preference; deviation must be documented with rationale
- **MAY** — permitted option

1.4 Glossary

Term	Definition
NCII	Non-Consensual Intimate Image
GO	Grievance Officer (as defined under IT Rules 2021)
IT Rules 2021	Information Technology (Intermediary Guidelines and Digital Media Ethics Code) Rules, 2021
Rule 3(2)(b)	The specific IT Rules provision requiring significant social media intermediaries to remove NCII within 24 hours
BNS	Bharatiya Nyaya Sanhita 2023 (successor to IPC)
DPDP	Digital Personal Data Protection Act 2023
POCSO	Protection of Children from Sexual Offences Act 2012
CSAM	Child Sexual Abuse Material
KYC	Know Your Customer
OTP	One-Time Password
pHash	Perceptual hash (Phase 2 only — not in scope for Phase 1)
Notice	A formally generated takedown request sent to a platform
Case	One victim's complete record: registration + all submitted URLs + all notices + all escalations
URL Token	A submitted URL treated as an opaque string — no HTTP fetch, no resolution, no preview

1.5 Document Version

Version	Date	Author	Summary
0.1	2026-05-12	—	Initial draft derived from PRD v0.2

2. System Context & Architecture

2.1 High-Level Component Diagram



2.2 Trust Boundaries

Boundary	Direction	Notes
Victim browser ↔ Frontend	Inbound	TLS 1.3 minimum; no inline scripts

Boundary	Direction	Notes
Frontend ↔ API	Internal	Same origin or API subdomain; JWT bearer token
API ↔ Database	Internal	Private subnet; mTLS
API → Email provider	Outbound only	No content from user-submitted URLs in email body payloads beyond the URL string
API → Platform APIs (Tier 1)	Outbound only	API keys in secrets manager; no user-submitted URL fetched
Victim browser → Aadhaar offline	Local only	XML parsing in browser OR backend verification of signed XML; Aadhaar number never transmitted to Asmita
NGO partner → API	Inbound	API key per NGO partner; scoped permissions

2.3 The No-Fetch Invariant (Hard Architectural Constraint)

NFI-01: *Asmita servers SHALL NEVER issue an HTTP request (or any equivalent network call) to a URL submitted by a victim. URLs are parsed locally for domain extraction only — no DNS lookup, no GET, no HEAD, no rendering.*

This invariant:

- MUST be enforced by a CI-level automated test that fails if any code path resolves user-submitted URLs (see §16.4)
- MUST be documented in the developer onboarding guide
- MUST be reviewed in every PR that touches URL processing code

Violation consequences: legal liability, content exposure to staff, privacy breach. This is not an optimization — it is a non-negotiable safety and legal constraint.

2.4 Time Zone Convention

- All database timestamps: stored in UTC
- All user-facing timestamps: displayed in IST (UTC+5:30)
- Escalation scheduler: operates in UTC, translates to IST for UI display
- Legal evidence packages: include both UTC and IST with explicit labels

3. Functional Requirements

FR-REG: Registration & Verification

FR-REG-01 — Email Registration The system MUST allow a victim to register using only an email address and age attestation.

- Acceptance criterion: A new account can be created with email + age selection + OTP verification, with no other mandatory fields.
- Verification: Integration test covering happy path and duplicate email rejection.

FR-REG-02 — Email OTP The system **MUST** send a 6-digit OTP to the provided email address. The OTP **MUST** expire in 10 minutes and be single-use.

- Acceptance criterion: OTP is invalidated after one successful use; expired OTPs are rejected with an appropriate message.
- Verification: Unit tests for OTP lifecycle; integration test confirming expiry behaviour.

FR-REG-03 — Age Attestation The system **MUST** present a binary age attestation: "I am under 18" / "I am 18 or older." Selecting under 18 **MUST** immediately branch to the minor pathway (FR-MIN) and **MUST NOT** continue the adult registration flow.

- Acceptance criterion: No adult pathway code executes after a minor selection; minor pathway is shown in full.
- Verification: E2E test confirming hard branch; code audit confirming no shared state between pathways.

FR-REG-04 — Optional Fields The system **SHOULD** collect, but not require: phone number (NGO follow-up), state and city (legal aid routing), victim name (for notices when consent given).

- Acceptance criterion: All optional fields can be omitted without blocking submission.

FR-REG-05 — Aadhaar Offline KYC (Optional) The system **MAY** offer identity verification via Aadhaar offline XML. If offered:

- Victim downloads their Aadhaar offline XML from UIDAI's resident portal
- Victim uploads the signed XML to Asmita
- The backend verifies the XML digital signature against UIDAI's published certificate chain (loaded locally — no call to UIDAI servers required for signature verification)
- System extracts and stores: full name, year of birth, verification timestamp, verification flag — no Aadhaar number stored at any point
- The stored Aadhaar number field **MUST NOT** exist in the database schema
- Acceptance criterion: Verification succeeds on a valid UIDAI-signed XML; fails on a tampered XML; Aadhaar number is not logged anywhere.
- Verification: Unit test with real UIDAI cert chain; database schema audit confirming absence of Aadhaar number column.

FR-REG-06 — DigiLocker Verification (Optional) The system **MAY** support DigiLocker OAuth as an alternative to Aadhaar offline KYC. Same storage rules: name + verification flag + timestamp only.

FR-REG-07 — Digital Declaration Before any URL can be submitted, the system **MUST** present and require explicit acknowledgment of the digital declaration:

"I confirm that I am the person depicted in this content, or an authorized representative with documented consent. I declare under the Information Technology Act, 2000 (Section 66) and IPC Section 191 (false statement) that this submission is truthful."

Legal note for engineering: The PRD cites "IPC Section 191" here. The BNS equivalent must be confirmed by the legal advisor before launch, as BNS renumbered many provisions. The legal advisor **MUST** sign off on the final declaration wording before the template is committed to the database and activated.

- The declaration text **MUST** be displayed in full — not hidden behind a "terms" link

- Acknowledgment method: an active checkbox or button labeled "I confirm and declare" — not a pre-checked box
- The declaration and its acknowledgment timestamp **MUST** be stored in the audit log (see §11)
- Acceptance criterion: URL submission form is unreachable without declaration acknowledgment; declaration text is visible on the same screen as the checkbox.
- Verification: E2E test; UI screenshot captured in test suite.

FR-REG-08 — Supporter Pathway (Scoped — Pending Product Decision) See §18 — Deferred Decision D-04. If enabled, a supporter **MUST** upload a signed victim consent form (PDF), and the victim **MUST** receive an email notification that a supporter has taken an action on their case.

FR-URL: URL Submission

FR-URL-01 — URL Input The system **MUST** accept one or more URLs per submission session. There is no hard limit on URLs per submission, but the rate limit of 10 URL tokens per verified account per 24 hours applies (FR-URL-04).

FR-URL-02 — URL Parsing (No-Fetch) For each submitted URL, the system **MUST**:

1. Validate that the string is a syntactically valid URL (scheme + host present)
 2. Extract the domain using a local URL parsing library — no DNS lookup, no HTTP request
 3. Look up the domain against the platform database (exact domain match + subdomain matching)
 4. Record: raw URL string, extracted domain, matched platform ID (or `null` for unknown)
 5. **MUST NOT**: resolve redirects, follow shortened URLs, fetch content, render previews, check if the URL is reachable
- Acceptance criterion: A malformed string is rejected with a user-friendly error. A valid URL's domain is extracted locally. No outbound network request is triggered for URL processing. CI test fails if any outbound call is made (§16.4).
 - Verification: Unit tests; CI no-fetch invariant test.

FR-URL-03 — Unknown Platform Handling If the extracted domain does not match any entry in the platform database, the URL **MUST** be flagged with status `platform_unknown` and routed to the human review queue. The notice **MUST NOT** be sent automatically for unknown platforms.

- Acceptance criterion: An unknown-domain URL appears in the admin review queue; no notice is dispatched automatically.
- Verification: Integration test.

FR-URL-04 — Rate Limiting The system **MUST** enforce: maximum 10 URL submissions per verified account per rolling 24-hour window. Additionally, per-IP rate limiting **MUST** be applied at the API gateway layer: maximum 30 URL submission requests per IP per hour (unauthenticated or across accounts). Per-email-domain registration rate limiting: maximum 3 accounts per email domain per 24 hours (to limit throwaway address clusters).

- Acceptance criterion: The 11th URL submission from the same account in 24 hours is rejected with HTTP 429 and a clear message.
- Verification: Unit test.

FR-URL-05 — Multi-Platform Spread A single case **MUST** support URLs across multiple platforms. Each URL is independently tracked and processed.

FR-URL-06 — URL Deduplication If the same URL is submitted more than once within the same case, the system SHOULD detect the duplicate and prompt the victim rather than creating duplicate notice records.

FR-NR: Notice Routing Engine

FR-NR-01 — Three-Tier Dispatch For each submitted URL with a known platform, the system MUST attempt notice dispatch in the following priority order:

1. **Tier 1 (Direct API):** If the platform's `routing_tier` = `api` and API credentials are configured, dispatch via platform API. Note: Meta's NCII removal flow is a partner program (StopNCII / Transparency Tools), not an open API. Google's `removals.google.com` is a web tool. Tier 1 is only available where a formal API integration has been established and credentials exist. Platforms without confirmed API access at launch are treated as Tier 2 regardless of their listed tier.
2. **Tier 2 (Grievance Officer Email):** If `routing_tier` = `email` (or Tier 1 fallback), generate and send an email notice to the platform's GO contact.
3. **Tier 3 (Web Form Handoff):** If `routing_tier` = `webform`, generate a pre-filled notice template and instructions for the victim to submit via the platform's own form.

FR-NR-02 — Notice Template Selection The system MUST select the correct notice template based on the platform's `notice_template_type`:

- `indian_it_rules`: Template A (IT Rules 2021 Rule 3(2)(b) primary)
- `international_dmca`: Template B (DMCA Section 512 primary + Indian law secondary)
- `pornographic_dmca`: Template C (DMCA primary + registrar/CDN escalation path)

Template content is stored in the database (editable by legal advisor via admin panel without code deployment — see FR-ADMIN-04).

FR-NR-03 — Dispatch Timing The first notice for each URL MUST be dispatched within 2 hours of URL submission (for accounts not in the human review queue).

- Acceptance criterion: p95 dispatch latency ≤ 2 hours, measured over a 30-day rolling window.
- Verification: Timing metric logged per notice; alert if p95 breaches 2h.

FR-NR-04 — Notice Idempotency Each notice dispatch MUST be keyed on `(case_id, submitted_url_id, tier, attempt_number)`. If the dispatch job fires twice due to a deploy, retry, or clock skew, the second fire MUST detect the existing record and MUST NOT send a duplicate notice.

- Acceptance criterion: Injecting a duplicate job into the queue results in exactly one notice sent.
- Verification: Unit test.

FR-NR-05 — Victim Confirmation After the first notice is dispatched for a case, the system MUST send a confirmation email to the victim containing: case reference number, notice tier used per platform, next escalation timeline, and a link to the case dashboard. The email MUST NOT list the submitted URLs — many victims are abused by a former partner who retains access to their email, and including URLs recreates the breadcrumb trail the victim is trying to suppress. URL details are available only via the authenticated dashboard.

FR-NR-06 — Notice Content — Mandatory Fields Every notice MUST include: Asmita case ID, content URL (the string token, included verbatim), legal citations appropriate to the template type, victim's digital declaration reference (not the declaration text, just a reference), Asmita's official contact email, and the

timestamp of sending. Notices MUST NOT include: the victim's name (unless victim explicitly opted in), the victim's phone number, the victim's Aadhaar number (never under any circumstances).

FR-NR-07 — Tier 1 API Acknowledgment For Tier 1 dispatches, the system MUST log: API response status code, platform-assigned ticket/reference ID (if returned), and timestamp. If the API returns an error, the system MUST fall back to Tier 2 (email) and log the fallback reason.

FR-NR-08 — Tier 3 Handoff Instructions For Tier 3 dispatches, the system MUST: present the pre-filled notice text to the victim in a copyable format, link directly to the platform's abuse/DMCA submission URL, and provide step-by-step instructions. The victim MUST be able to confirm "I submitted this" to update the case status to `handoff_confirmed`. Platform links in Tier 3 instructions MUST NOT be generated dynamically from victim-submitted URLs.

FR-ESC: Auto-Escalation Scheduler

FR-ESC-01 — Escalation Timeline For each active notice, the system MUST execute the following timeline:

Elapsed	Condition	Action
T+0	Notice dispatched	Confirmation email to victim (FR-NR-05)
T+24h	No <code>acknowledged</code> or <code>removed</code> status	Send escalation notice (same contact as original); email victim that escalation was sent
T+48h	No <code>acknowledged</code> or <code>removed</code> status	Send notice to platform's secondary Indian GO (if separate contact in DB); email victim with instructions to file cybercrime.gov.in complaint
T+7 days	No <code>removed</code> status	Generate 7-day escalation package (PDF); email to victim; update case status to <code>legal_package_ready</code>

FR-ESC-02 — "No Response" Definition A notice is considered unacknowledged if no response has been logged in the `notices` table (either via API callback, email reply parsing, or manual admin entry) within the elapsed time.

FR-ESC-03 — Scheduler Idempotency The escalation scheduler MUST be idempotent. Each escalation step is keyed on `(notice_id, escalation_level)`. Firing the scheduler twice at T+24h MUST NOT produce two escalation emails.

- Acceptance criterion: Double-fire test results in exactly one escalation action per level.
- Verification: Unit test.

FR-ESC-04 — Clock Source The escalation scheduler MUST use the database server's UTC clock as the authoritative time source, not the application server clock, to avoid drift across multiple instances.

FR-ESC-05 — 7-Day Legal Package The 7-day legal package PDF MUST include: case reference ID, all submitted URLs (as string tokens), all notices sent (platform, tier, timestamp, response), escalation history, victim declaration reference, and a section titled "For use in FIR / Police Complaint / Court Filing." See §12 for PDF/font requirements.

FR-DASH: Case Tracking Dashboard

FR-DASH-01 — Authentication Victims access the dashboard via case reference number + email OTP. No passwords. Session TTL: 4 hours of inactivity (see §7).

FR-DASH-02 — Per-URL Status The dashboard **MUST** display per-URL status using a clear, non-technical label set:

- **Notice Sent** (notice dispatched, no acknowledgment yet)
- **Acknowledged** (platform confirmed receipt)
- **Content Removed** (platform confirmed removal or victim marked resolved)
- **Escalated** (second-level or third-level notice sent)
- **Awaiting Review** (in human review queue, notice not yet sent)
- **Legal Package Ready** (7-day package generated)
- **Manually Resolved** (victim marked as resolved outside Asmita)

FR-DASH-03 — Add URLs Victim **MUST** be able to add new URLs to an existing case from the dashboard. New URLs follow the same submission and routing flow.

FR-DASH-04 — Manual Resolution Victim **MUST** be able to mark any URL as "manually resolved" with a timestamp. This stops further escalation for that URL.

FR-DASH-05 — Case Record PDF Download Victim **MUST** be able to download their complete case record as a PDF at any time. PDF **MUST** include: case ID, registration date, all submitted URLs, all notices sent with timestamps, escalation log, platform responses. See §12 for rendering requirements.

FR-DASH-06 — Account Deletion Victim **MUST** be able to request deletion of their entire case record. Deletion **MUST** execute within 30 days. The audit log entry for the deletion request itself is retained (see §11 — audit log immutability).

FR-SUP: Support & Resources

FR-SUP-01 — Always Visible Support resources **MUST** be accessible from every page of the application — not hidden behind a menu.

FR-SUP-02 — Mandatory Resources The support page **MUST** include:

- iCall (TISS): 9152987821
- Cyber Peace Foundation helpline
- Red Dot Foundation
- CHILDLINE: 1098 (visible on all pages, not only in minor pathway)
- cybercrime.gov.in step-by-step filing guide
- District Legal Services Authority directory (state-wise)
- FAQ: Does Asmita see my content? (Answer: No — URL is a string token; content is never fetched or viewed by any Asmita system or staff)

FR-SUP-03 — FIR Guide A step-by-step guide for filing an NCII FIR in India **MUST** be available in Hindi and English.

FR-MIN: Minor / POCSO Pathway

This section is non-negotiable under Indian law. No part of it may be relaxed or deferred.

FR-MIN-01 — Hard Branch If a user selects "I am under 18" at age attestation, the adult registration and URL submission flows MUST NOT be accessible from that session. No shared code path, no shared state, no "go back" navigation to the adult flow from the minor pathway screens.

FR-MIN-02 — Minor Pathway Content The minor pathway MUST display, prominently and in order:

1. TakeItDown (NCMEC) referral with direct link and step-by-step instructions
2. cybercrime.gov.in filing instructions for CSAM
3. CHILDLINE: 1098 in large, accessible type
4. NGO contacts: Cyber Peace Foundation, Red Dot Foundation

FR-MIN-03 — No Data Storage for Minors No case record, no URL submission, no notice, no hash, no personal data MUST be stored for a minor pathway user. The minor pathway is informational only — Asmita does not process takedowns for minors directly.

- Acceptance criterion: Database audit after a minor pathway session shows zero rows created in `cases`, `submitted_urls`, `notices`, or any PII table.
- Verification: Integration test + database audit.

FR-MIN-04 — No Session Persistence The minor pathway MUST NOT create a login session, assign a case reference number, or set any authentication cookies.

FR-MIN-05 — POCSO Reporting Protocol Before launch, the legal advisor MUST define and document Asmita's mandatory reporting obligation under POCSO if CSAM-related submissions are received through any channel. This document MUST be completed before production deployment. (This is a pre-launch governance requirement, not a code requirement.)

FR-ADMIN: Admin Panel

FR-ADMIN-01 — Access Control (RBAC)

Role	Permissions
<code>super_admin</code>	All permissions; user management
<code>legal_advisor</code>	Edit notice templates; read all cases; cannot delete cases
<code>case_reviewer</code>	View and action the human review queue; cannot edit templates
<code>go_editor</code>	Edit GO database entries; view platform response rates
<code>support_agent</code>	View specific case by case ID; add manual resolution notes

All admin panel actions MUST be logged in the audit log with user ID and timestamp.

FR-ADMIN-02 — Human Review Queue The admin panel MUST present a queue of cases/URLs flagged by the abuse detection system. For each flagged item, the reviewer sees: the submitted URL (string only — not rendered), the account's submission history, the flag reason. Reviewer actions: approve (dispatch notice), reject (notify victim), escalate to senior reviewer.

- MUST NOT display or attempt to render the content at the URL at any time.

FR-ADMIN-03 — Platform Response Rate Dashboard The admin panel MUST display per-platform: total notices sent, acknowledgment count, removal confirmed count, non-response count, median response time, response rate (%). This data drives both operational decisions and Phase 2 partnership

conversations.

FR-ADMIN-04 — Notice Template Editor The legal advisor **MUST** be able to edit notice template content through the admin panel without a code deployment. Template changes **MUST** be versioned: the version active at the time each notice was sent **MUST** be recorded in the notice log.

FR-ADMIN-05 — GO Database Editor The GO editor role **MUST** be able to: add a platform entry, update GO contact details, record the verification method (direct page check / phone verification / legal advisor confirmation), record the last-verified date. Entries not verified in the past 60 days **MUST** be flagged as **stale** in the UI and in the platform database.

- Change history **MUST** be maintained: who changed what, when, what was the previous value, what source was verified.

FR-ADMIN-06 — NGO Vouching NGO partner users (API key holders) **MUST** be able to flag a case as "NGO-verified." Vouched cases: rate limits lifted, identity noted in notice as NGO-verified, prioritised in dispatch queue. NGO vouching API calls **MUST** be logged in the audit log.

4. Notice Routing State Machine

Each submitted URL record transitions through the following states:



Parallel escalation paths (do not block main state):

T+24h: NOTICE_SENT → ESCALATED_L1 (if not ACKNOWLEDGED)
 T+48h: ESCALATED_L1 → ESCALATED_L2 (if not ACKNOWLEDGED)
 T+7d: Any non-REMOVED → LEGAL_PACKAGE_READY

Terminal states from any non-REMOVED state:

→ MANUALLY_RESOLVED (victim action)
 → REJECTED (admin review rejection)
 → PLATFORM_UNKNOWN (no matching platform; routes to review queue)

State transitions MUST be recorded in the `notices` table with timestamps. Transitions MUST be append-only — previous states are never overwritten.

5. Data Model

5.1 Schema

victims

```
CREATE TABLE victims (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  email_encrypted   BYTEA NOT NULL,           -- AES-256-GCM, KMS-managed key
  email_hash        TEXT NOT NULL UNIQUE,     -- SHA-256(lowercase(email)); for lookups
  name_encrypted    BYTEA,                    -- null unless victim consented
  phone_encrypted   BYTEA,                    -- null unless provided
  state             TEXT,
  city              TEXT,
  is_verified       BOOLEAN NOT NULL DEFAULT FALSE,
  identity_verified BOOLEAN NOT NULL DEFAULT FALSE, -- Aadhaar/DigiLocker
  identity_method    TEXT,                    -- 'aadhaar_offline' | 'digilocker' | null
  identity_name_enc  BYTEA,                    -- Name from Aadhaar/DigiLocker, encrypted
  identity_verified_at TIMESTAMPTZ,
  ngo_vouched       BOOLEAN NOT NULL DEFAULT FALSE,
  ngo_partner_id     UUID REFERENCES ngo_partners(id),
  declaration_signed_at TIMESTAMPTZ,          -- digital declaration timestamp
  created_at         TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  deleted_at         TIMESTAMPTZ              -- soft delete; hard-delete job runs after 30
days
  -- NOTE: Aadhaar number MUST NEVER be stored in this table or any other table.
  -- There is no column for it; any schema migration adding one must be rejected.
);
```

cases

```
CREATE TABLE cases (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  case_ref          TEXT NOT NULL UNIQUE,     -- human-readable: ASMITA-YYYYMM-NNNNN
  victim_id         UUID NOT NULL REFERENCES victims(id),
  status            TEXT NOT NULL DEFAULT 'active',
  created_at        TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  last_activity     TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  deleted_at        TIMESTAMPTZ
);
```

submitted_urls

```
CREATE TABLE submitted_urls (
  id          UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  case_id     UUID NOT NULL REFERENCES cases(id),
  raw_url     TEXT NOT NULL,           -- stored as-is; never fetched
  domain      TEXT NOT NULL,          -- extracted by local parser
  platform_id UUID REFERENCES platforms(id), -- null if unknown
  status      TEXT NOT NULL DEFAULT 'queued',
  flagged     BOOLEAN NOT NULL DEFAULT FALSE,
  flag_reason TEXT,
  submitted_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  CONSTRAINT url_per_case_unique UNIQUE (case_id, raw_url)
);
```

platforms

```
CREATE TABLE platforms (
  id          UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name        TEXT NOT NULL,
  domains     TEXT[] NOT NULL,       -- all known domains for this platform
  routing_tier TEXT NOT NULL,        -- 'api' | 'email' | 'webform'
  notice_template_type TEXT NOT NULL, -- 'indian_it_rules' | 'international_dmca' | 'pornographic_dmca'
  go_email    TEXT,                  -- Grievance Officer email
  go_name     TEXT,
  go_secondary_email TEXT,           -- secondary contact (IT Rules)
  webform_url TEXT,                  -- for Tier 3 only
  api_endpoint_key TEXT,             -- references secrets manager entry name
  last_verified_at TIMESTAMPTZ,
  verified_by  UUID REFERENCES admin_users(id),
  verification_source TEXT,
  response_rate_7d NUMERIC(5,2),    -- computed field, refreshed by daily job
  is_stale     BOOLEAN NOT NULL DEFAULT FALSE, -- set by daily maintenance job; last_verified_at > 60 days → true
  created_at   TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  updated_at   TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

platform_go_history

```
CREATE TABLE platform_go_history (
  id          UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  platform_id UUID NOT NULL REFERENCES platforms(id),
  changed_by  UUID NOT NULL REFERENCES admin_users(id),
  changed_at  TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  field_changed TEXT NOT NULL,
  old_value   TEXT,
  new_value   TEXT,
  source      TEXT -- URL or description of source verified
);
```

notice_templates

```
CREATE TABLE notice_templates (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  template_type     TEXT NOT NULL,
  version           INTEGER NOT NULL,
  is_active         BOOLEAN NOT NULL DEFAULT FALSE,
  subject_hi        TEXT NOT NULL,
  subject_en        TEXT NOT NULL,
  body_hi           TEXT NOT NULL,
  body_en           TEXT NOT NULL,
  created_by        UUID REFERENCES admin_users(id),
  created_at        TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  reviewed_by       UUID REFERENCES admin_users(id), -- legal advisor sign-off
  reviewed_at       TIMESTAMPTZ
);
-- Only one active template per type at a time (partial unique index):
CREATE UNIQUE INDEX ON notice_templates (template_type) WHERE is_active;
```

notices

```
CREATE TABLE notices (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  submitted_url_id  UUID NOT NULL REFERENCES submitted_urls(id),
  case_id           UUID NOT NULL REFERENCES cases(id),
  tier              INTEGER NOT NULL CHECK (tier IN (1, 2, 3)),
  attempt_number    INTEGER NOT NULL DEFAULT 1,
  template_id       UUID NOT NULL REFERENCES notice_templates(id),
  template_version  INTEGER NOT NULL,
  idempotency_key   TEXT NOT NULL UNIQUE, -- (case_id||url_id||tier||attempt)
  status            TEXT NOT NULL DEFAULT 'queued',
  sent_at           TIMESTAMPTZ,
  acknowledged_at   TIMESTAMPTZ,
  removed_at        TIMESTAMPTZ,
  platform_ref_id   TEXT, -- platform's own ticket/reference ID
  response_body_enc BYTEA, -- encrypted platform response, if any
  created_at        TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

escalations

```
CREATE TABLE escalations (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  notice_id         UUID NOT NULL REFERENCES notices(id),
  level             INTEGER NOT NULL CHECK (level IN (1, 2, 3)), -- 24h/48h/7d
  idempotency_key   TEXT NOT NULL UNIQUE,
  fired_at          TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  action_taken      TEXT NOT NULL -- 'email_sent' | 'victim_notified' | 'package_generated'
);
```

audit_log

```
CREATE TABLE audit_log (
  id          BIGSERIAL PRIMARY KEY,
  event_time  TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  actor_type  TEXT NOT NULL,    -- 'victim' | 'admin' | 'system' | 'ngo_partner'
  actor_id    UUID,
  event_type  TEXT NOT NULL,    -- e.g. 'declaration_signed' | 'notice_sent' | 'url_submitted'
  case_id     UUID REFERENCES cases(id),
  payload     JSONB,           -- non-PII event data
  ip_hash     TEXT             -- SHA-256(IP); for abuse investigation, not stored raw
);
-- This table is append-only. No UPDATE or DELETE permitted via application.
-- Enforced by: PostgreSQL row-security policy + application-level ORM configuration.
```

5.2 Encryption Policy

Field	Encryption	Key Management
victims.email_encrypted	AES-256-GCM	AWS KMS customer-managed key; per-record nonce
victims.name_encrypted	AES-256-GCM	Same KMS key
victims.phone_encrypted	AES-256-GCM	Same KMS key
victims.identity_name_enc	AES-256-GCM	Same KMS key
notices.response_body_enc	AES-256-GCM	Same KMS key
All other fields	Not encrypted at field level	Protected by database-level encryption (RDS encryption at rest)

KMS key rotation: annual automatic rotation. Key usage logging enabled. No application code holds raw key material — all encrypt/decrypt operations go through the KMS API.

5.3 Retention Policy

Data	Retention	Deletion mechanism
Case records (active)	Until victim requests deletion	Soft-delete flag; hard delete job runs within 30 days
Case records (inactive)	2 years from last activity	Automated job; victim notified 30 days before
OTP tokens	10 minutes	TTL-based expiry
Session tokens	4 hours inactivity	TTL-based expiry
Audit log	Indefinite	Exempt from case deletion; append-only
Admin panel access logs	7 years	Compliance retention

6. API Specifications

6.1 Base URL Convention

- Production: <https://api.asmita.org/v1/>

- All endpoints require HTTPS. HTTP MUST redirect to HTTPS.
- API versioning: path-based (`/v1/`). Breaking changes require a new version.

6.2 Authentication

All victim-facing endpoints require a valid session token (Bearer) obtained via the OTP flow. Admin endpoints require admin session token + RBAC check. See §7.

6.3 Victim-Facing Endpoints

POST /v1/auth/register Create a new victim account.

- Body: `{ email, age_over_18: bool }`
- Response: `{ message: "OTP sent" }`
- On `age_over_18: false`: response redirects to minor pathway; no account created.
- Rate limit: 3 requests per IP per hour.

POST /v1/auth/verify-otp Verify OTP and issue session token.

- Body: `{ email, otp }`
- Response: `{ session_token, case_ref (if existing case), expires_at }`

POST /v1/profile/declaration Record digital declaration acknowledgment.

- Body: `{ acknowledged: true }`
- Response: `{ declaration_logged_at }`
- Precondition: authenticated session; declaration not already signed.

POST /v1/profile/identity/aadhaar Submit Aadhaar offline XML for verification.

- Body: multipart/form-data with `aadhaar_xml` file
- Server verifies XML signature; extracts name + year of birth; stores encrypted name + verification flag.
- Response: `{ verified: bool, name_extracted: bool }`
- Aadhaar number MUST NOT appear in response or logs.

POST /v1/cases Create a new case.

- Body: `{ optional: phone, state, city, name_consent: bool }`
- Response: `{ case_id, case_ref }`

POST /v1/cases/{case_id}/urls Submit one or more URLs to a case.

- Body: `{ urls: [string] }`
- Server parses domains locally; no outbound requests.
- Response: `{ submitted: [{ url, domain, platform_name, routing_tier, status }] }`
- Rate limit: per FR-URL-04.

GET /v1/cases/{case_id} Get full case status.

- Response: `{ case_ref, created_at, urls: [{ raw_url, platform, status, notices: [...] }], escalations: [...] }`

POST /v1/cases/{case_id}/urls/{url_id}/resolve Mark a URL as manually resolved.

- Body: `{ note: string (optional) }`

GET /v1/cases/{case_id}/export Download case record as PDF.

- Response: `application/pdf`

DELETE /v1/cases/{case_id} Request case deletion.

- Triggers soft-delete; hard delete within 30 days; audit log entry created.

6.4 Admin Endpoints (abbreviated)

All under `/v1/admin/` — require `admin` session token + appropriate RBAC role.

- `GET /v1/admin/review-queue` — list flagged URLs for human review
- `POST /v1/admin/review-queue/{item_id}/approve`
- `POST /v1/admin/review-queue/{item_id}/reject`
- `GET /v1/admin/platforms` — list all platform entries
- `PUT /v1/admin/platforms/{id}` — update GO contact details
- `GET /v1/admin/platforms/{id}/history` — GO change history
- `GET /v1/admin/templates` — list notice templates
- `POST /v1/admin/templates` — create new template version
- `PUT /v1/admin/templates/{id}/activate` — make a template version active
- `GET /v1/admin/metrics` — response rate dashboard data
- `POST /v1/ngo/vouch/{case_id}` — NGO partner vouching (API key auth)

6.5 External Platform Integrations (Tier 1)

Meta Graph API (NCII reporting)

- Endpoint: per Meta's current Transparency Tools API
- Auth: App token stored in AWS Secrets Manager
- Payload: case reference + URL string token (no content)
- Response: log platform reference ID; update notice status

Google SafeSearch / Removal API

- Endpoint: per Google's current policy removal API documentation
- Same auth + logging pattern as Meta

For both: if API credentials are not configured or API returns 5xx, the system MUST fall back to Tier 2 (email) and log the fallback.

7. Authentication & Session Management

AUTH-01 — OTP Generation OTPs MUST be: 6 digits, cryptographically random (not sequential), unique per request, stored hashed (bcrypt or Argon2id — not plaintext), expired after 10 minutes, invalidated after one successful use.

AUTH-02 — Session Tokens Session tokens: JWT signed with RS256 (asymmetric) or opaque random token stored server-side. Token contains: `victim_id`, `case_id` (if applicable), `issued_at`, `expires_at`. TTL: 4 hours of inactivity (sliding window). Absolute maximum session duration: 24 hours regardless of activity.

AUTH-03 — Session Binding Sessions SHOULD be bound to User-Agent. A session MUST NOT be transferable across different email addresses.

AUTH-04 — Admin Sessions Admin sessions: separate auth flow, separate token namespace, 8-hour absolute TTL, MFA MUST be enabled (TOTP). Admin session tokens MUST NOT be usable on victim-facing endpoints.

AUTH-05 — Brute Force Protection OTP verification: maximum 5 attempts per OTP; after 5 failures, the OTP is invalidated and a new one must be requested. Maximum 10 OTP requests per email per hour.

AUTH-06 — No Passwords The system MUST NOT implement a password-based login for victims. Email OTP is the sole authentication method for victims.

8. Email Infrastructure

EMAIL-01 — Provider Postmark or Resend. Selection MUST be made before development begins (not during). The chosen provider MUST support: DKIM signing, SPF records, bounce webhook, complaint webhook, dedicated sending domain.

EMAIL-02 — DNS Configuration (MUST before any notice is sent)

- SPF record for the sending domain
- DKIM: 2048-bit key minimum
- DMARC policy: `p=quarantine` at launch; upgrade to `p=reject` after monitoring for 30 days
- BIMBI (optional, Phase 2): Brand Indicators for Message Identification for trust signals

EMAIL-03 — Dedicated Sending Domain Notices MUST be sent from a subdomain dedicated to legal notices (e.g., `notices@notice.asmita.org`) distinct from transactional email (e.g., OTP, case updates). Separating reputation pools protects notice deliverability if transactional volume causes issues.

EMAIL-04 — Bounce & Complaint Handling The email provider's bounce webhook MUST be wired to the backend. Permanent bounces (the GO email address is invalid): the platform entry MUST be flagged as `go_contact_invalid` in the database and a `stale` alert raised. Complaint callbacks: logged to audit trail.

EMAIL-05 — Deliverability Monitoring The admin metrics dashboard MUST include: bounce rate per platform (target <2%), spam complaint rate (target <0.1%), delivery confirmation rate. If a platform's notice emails have a >5% bounce rate, the GO database record MUST be automatically flagged for re-verification.

EMAIL-06 — Warm-Up If using a new dedicated IP: follow the email provider's recommended IP warm-up schedule before sending high volumes. Do not send more than the provider's recommended daily volume during warm-up.

EMAIL-07 — No URL Content in Email Body Email notice bodies MUST contain the URL string token as literal text. The email template engine MUST NOT make any HTTP request to the URL, resolve the URL, or embed any preview or metadata derived from the URL.

9. Verification & Abuse-Prevention Pipeline

ABU-01 — Digital Declaration as Primary Deterrent See FR-REG-07. The declaration text MUST be rendered in full, in the active language, before the URL submission form is accessible. The signed declaration is stored in the audit log with the IP hash, session ID, and timestamp.

ABU-02 — OTP Verification Gate No notice MUST be dispatched for an account whose email is not OTP-verified.

ABU-03 — Rate Limiting Layers Three independent rate-limiting layers MUST be implemented:

1. Per-IP (API gateway): 30 URL submission requests per IP per hour
2. Per-account: 10 URL submissions per verified account per 24-hour rolling window
3. Per-email-domain: 3 account registrations per email domain per 24 hours (e.g., @gmail.com is not domain-limited, but @tempmail.xyz would be if patterns emerge)

ABU-04 — Automated Flagging Signals The following signals MUST trigger flagging (notice held in human review queue):

- More than 5 URL submissions from one account in any 1-hour window
- Submitted URL domain appears in the platform database as a public/non-intimate category (e.g., news sites, government sites — a blocklist maintained by admin)
- Submitted URL points to the same platform account/profile page as a previously rejected submission
- Account is newly registered (< 1 hour old) and submitting more than 3 URLs at once
- Multiple submissions from the same IP targeting the same platform user handle

ABU-05 — Human Review Queue SLA Flagged cases MUST be reviewed within 4 business hours. The admin dashboard MUST display queue age and alert if any item exceeds 4 hours.

ABU-06 — Aadhaar Offline XML Signature Verification UIDAI's published certificate chain MUST be bundled with the application (not fetched from UIDAI at runtime). The XML digital signature MUST be verified against this certificate chain before extracting any data. An XML that fails signature verification MUST be rejected with no data extracted.

ABU-07 — Platform Linkage (Credibility Signal, Optional) If the victim provides a URL to their own social media profile, the system SHOULD note the connection in the case record and include it in the notice as a credibility signal (with victim's consent).

10. Privacy & DPDP Technical Controls

PRIV-01 — No Content Storage The system MUST NOT store, cache, or log any content fetched from user-submitted URLs. No image bytes, no video frames, no page HTML. This is an extension of NFI-01.

PRIV-02 — Encryption at Rest All PII fields listed in §5.2 MUST be encrypted at field level using KMS. The database disk is also encrypted (RDS encryption). Field-level encryption provides defence in depth beyond disk encryption.

PRIV-03 — Encryption in Transit All internal and external connections MUST use TLS 1.2 minimum; TLS 1.3 preferred. No unencrypted plaintext channels.

PRIV-04 — Data Minimisation The system MUST NOT collect data not required to process a takedown notice or track its status. New fields proposed during development MUST be reviewed against this principle before implementation.

PRIV-05 — Purpose Limitation Victim data MUST NOT be used for any purpose other than processing takedown notices and routing support referrals. Aggregate, anonymized metrics (e.g., response rates by platform) are permitted.

PRIV-06 — Consent Record The explicit consent given at registration **MUST** be stored: what was consented to, the version of the consent text, and the timestamp. If consent text is updated, existing users **MUST NOT** be assumed to have consented to the new version.

PRIV-07 — Deletion on Request Case deletion (FR-DASH-06): within 30 days. The deletion job **MUST** hard-delete all PII from `victims`, `cases`, `submitted_urls`, and `notices`. The audit log entry for the deletion request is exempt — it records the fact of deletion, not the PII itself. See §11.

PRIV-08 — Anonymisation in Notices Notices sent to platforms **MUST** use the Asmita case reference ID, not the victim's name, unless the victim explicitly opted in to name disclosure. The case reference is the victim's identifier in all external communications.

PRIV-09 — DPDP Alignment Architecture is designed to meet DPDP 2023 principles. Once DPDP implementation rules are notified by the government, a legal review **MUST** be conducted and any additional requirements implemented before they take effect. This is tracked as a standing obligation.

11. Audit Logging

AUDIT-01 — Append-Only Enforcement The `audit_log` table **MUST** be append-only. This is enforced at two levels:

1. PostgreSQL row-security policy: the application database user has `INSERT` but not `UPDATE` or `DELETE` on `audit_log`.
2. ORM / repository layer: no `update()` or `delete()` method is exposed for the audit log entity.

AUDIT-02 — Events Logged The `payload` field **MUST NOT** contain: raw email addresses, victim name, phone number, Aadhaar number, or raw URL strings beyond the domain. For URL submission events, log the domain and platform ID, not the full raw URL. The raw URL is stored in `submitted_urls` — the audit log records the event, not a copy of the PII.

The following events **MUST** generate an audit log entry:

Event	Actor	Key Payload
Account registration	victim	email_hash, age_attestation
OTP verified	system	email_hash
Declaration signed	victim	declaration_version, timestamp
URL submitted	victim	domain, platform_id, session_id
URL flagged	system	flag_reason
Notice dispatched	system	notice_id, tier, template_version
Escalation fired	system	notice_id, escalation_level
Case export (PDF)	victim	case_id
Case deletion requested	victim	case_id
Case hard-deleted	system	case_id (only — no PII)
Admin review approved	admin	admin_id, item_id
Admin review rejected	admin	admin_id, item_id, reason

Event	Actor	Key Payload
GO database entry changed	admin	platform_id, field, old/new value
Template activated	admin	template_id, version
NGO vouching	ngo_partner	case_id, partner_id
Identity verification	system	method, result (no Aadhaar number)

AUDIT-03 — Hash Chaining (Legal Evidence Integrity) For legal evidence value, the audit log SHOULD implement hash chaining: each row's hash is computed over `(id, event_time, event_type, payload, prev_hash)`. This allows verification that the log has not been tampered with. If hash chaining is not implemented at launch, it MUST be added before the 7-day legal package feature is live.

AUDIT-04 — Log Retention Audit logs are retained indefinitely and are excluded from victim case deletion.

12. Internationalisation (i18n)

I18N-01 — Languages at Launch Hindi (hi-IN) and English (en-IN). Language toggle MUST be available on every page, including the landing page, before authentication.

I18N-02 — Legal Text Translation All legal citations, the digital declaration, and notice templates MUST be translated by a qualified translator and reviewed by the legal advisor before launch. Machine translation is not acceptable for legal text.

I18N-03 — Font Requirements The application MUST use a web font that correctly renders Devanagari script (e.g., Noto Sans Devanagari). The font MUST be loaded from self-hosted assets — not from a third-party CDN that could expose victim IP addresses.

I18N-04 — PDF Font Requirements PDFs generated for case records and 7-day legal packages MUST embed a Devanagari-capable font. The PDF renderer MUST NOT fall back to a font that cannot render Hindi text. Recommended: Puppeteer/Chromium or a well-tested PDF library with Unicode support verified for Devanagari.

I18N-05 — Locale-Aware Dates Dates in victim-facing UI and PDF exports MUST be formatted in IST with both numeric date and written month name in the active language.

I18N-06 — Input Method (IME) The URL submission field MUST remain in Latin/ASCII input mode regardless of the browser's active language (URLs are Latin characters). Other text fields MUST respect the browser's active IME.

13. Non-Functional Requirements

13.1 Performance

NFR-PERF-01 — Mobile Performance Budget The application targets mobile-first India users on 3G/4G connections.

- Largest Contentful Paint (LCP): ≤ 3 seconds on simulated 4G (Chrome DevTools throttling)
- First Contentful Paint (FCP): ≤ 1.5 seconds on 4G
- JavaScript bundle (initial load): ≤ 200 KB gzipped

- Total page weight (landing page): ≤ 500 KB
- These targets MUST be verified in CI using Lighthouse or equivalent.

NFR-PERF-02 — API Response Times

- Authentication (OTP verify): $p95 \leq 500\text{ms}$
- URL submission (local parse + DB write): $p95 \leq 1$ second
- Case dashboard load: $p95 \leq 2$ seconds
- PDF export: $p95 \leq 10$ seconds

NFR-PERF-03 — Notice Dispatch First notice dispatched within 2 hours of URL submission — $p95$ target (see FR-NR-03).

13.2 Availability

NFR-AVAIL-01 The web application MUST target 99.5% monthly uptime (≤ 3.6 hours downtime/month). This accommodates a small team and is achievable on managed AWS services.

NFR-AVAIL-02 The escalation scheduler MUST continue to process escalations during web application downtime. It is a separate background worker process.

13.3 Scalability

Phase 1 targets (from PRD §15): 100 cases processed. The system MUST be able to handle 10x this (1,000 cases) without architectural changes, to avoid re-engineering before Phase 2. This is the only scalability target for Phase 1.

13.4 Accessibility

NFR-ACC-01 The application MUST meet WCAG 2.2 Level AA (current version as of 2023). Given the trauma-informed UX requirement, specific additional requirements:

- No auto-playing media
- No flashing content
- All images have alt text
- Focus management on modal dialogs (especially the declaration modal)
- High-contrast mode support

NFR-ACC-02 Accessibility MUST be tested with a screen reader (NVDA or VoiceOver) before launch. The support resources page and the minor pathway MUST be fully accessible without a mouse.

13.5 Security

NFR-SEC-01 — OWASP Top 10 The application MUST be reviewed against OWASP Top 10 before launch. Particular attention to: injection (SQL injection in URL parsing), broken access control (victim accessing another victim's case), insecure direct object references (case IDs must not be guessable — UUID v4), security misconfiguration.

NFR-SEC-02 — Content Security Policy A strict CSP MUST be configured. No `unsafe-inline` in script-src. No `unsafe-eval`.

NFR-SEC-03 — Dependency Scanning `npm audit` / `pip audit` (or equivalent) MUST run in CI. Critical vulnerabilities block deployment.

NFR-SEC-04 — Secret Management No API keys, database credentials, or KMS key IDs in source code or environment files committed to the repository. All secrets via AWS Secrets Manager or equivalent. CI/CD pipelines access secrets via IAM role, not static credentials.

NFR-SEC-05 — Security Audit A third-party security audit SHOULD be conducted before public launch. This is separate from the OWASP self-review.

14. Observability

OBS-01 — Structured Logging All application logs MUST be structured (JSON). Every log line includes: timestamp (UTC), service name, log level, trace ID (for request correlation), actor type (victim/admin/system), event type. PII MUST NOT appear in logs — email addresses are replaced with `email_hash`.

OBS-02 — Metrics The following metrics MUST be collected and dashboarded:

Metric	Alert Threshold
Notice dispatch p95 latency	> 2 hours
Notice email bounce rate	> 5% per platform
Escalation queue backlog	> 10 items older than 4 hours
Human review queue age	> 4 hours for any item
OTP delivery failure rate	> 2%
API error rate (5xx)	> 1% over 5 minutes
Escalation scheduler lag	> 30 minutes behind

OBS-03 — Alerting Alerts MUST be routed to an on-call channel (Slack, PagerDuty, or equivalent). Critical alerts (notice dispatch failure, scheduler down) require acknowledgment within 30 minutes.

OBS-04 — Tracing Distributed tracing (OpenTelemetry or equivalent) SHOULD be implemented to trace a URL submission from API entry through URL parsing, abuse detection, notice generation, and dispatch. This is essential for debugging why a notice was delayed.

OBS-05 — Health Checks Both the API server and the escalation scheduler MUST expose a `/health` endpoint. The scheduler's health check MUST report: last run time, number of pending escalations, and last error (if any).

15. Infrastructure & Deployment

INFRA-01 — Region Primary deployment: AWS `ap-south-1` (Mumbai) for DPDP data residency. No data MUST be stored or processed in regions outside India, including logs and backups.

INFRA-02 — Environments Three environments: `development` (local), `staging` (ap-south-1, non-production data), `production` (ap-south-1). Staging MUST be functionally identical to production. No testing on production data.

INFRA-03 — Database AWS RDS PostgreSQL with: encryption at rest (AWS KMS), automated backups (7-day retention in `ap-south-1`), Multi-AZ for production, read replicas if needed for admin dashboard queries (so admin reads don't impact victim-facing writes).

INFRA-04 — No File Storage in Phase 1 No S3 bucket or equivalent blob storage. The only file received from users in Phase 1 is the Aadhaar offline XML (for identity verification) — this is processed in-memory, not stored to disk or S3. Supporter consent form PDFs are also processed in-memory and their hash stored, not the file itself.

INFRA-05 — CI/CD Every commit to main MUST pass: unit tests, integration tests, no-fetch invariant test (§16.4), OWASP dependency scan, Lighthouse performance check. Deployment to staging is automatic on main branch merge. Deployment to production requires a manual approval step.

INFRA-06 — Secrets All secrets in AWS Secrets Manager. Secret rotation: API keys rotated every 90 days; KMS keys rotated annually (automatic). No static IAM user credentials — all CI/CD uses IAM roles.

INFRA-07 — Backups & Disaster Recovery RDS automated backups: daily snapshots, 7-day retention, stored in `ap-south-1`. Recovery Time Objective (RTO): ≤ 4 hours. Recovery Point Objective (RPO): ≤ 24 hours. DR plan MUST be documented and tested before public launch.

INFRA-08 — Evidentiary Data Durability The `audit_log` table and case records are the legal evidence chain for victims. Backup of these tables MUST use cross-region replication to `ap-south-2` (AWS Hyderabad, available as of 2023) for DR, while keeping primary storage in `ap-south-1`. All replicated data MUST remain within India for DPDP compliance.

16. Testing Strategy

16.1 Unit Tests

Coverage target: 80% line coverage for business logic. Required for: URL parser (domain extraction), notice template engine (variable substitution, template selection), OTP lifecycle, escalation timeline calculations, abuse detection signal scoring.

16.2 Integration Tests

Required for: OTP registration → case creation → URL submission → notice dispatch → case dashboard reads. Full notice routing flow per tier. Escalation scheduler firing at T+24h, T+48h, T+7d. Minor pathway hard branch (confirmed: no data written to database). Case deletion workflow.

16.3 End-to-End Tests

Browser-level E2E (Playwright or Cypress). Scenarios required:

1. Happy path: register → declare → submit URL → view case dashboard → download PDF
2. Minor pathway: age selection → minor pathway shown → no session created
3. Escalation visibility: dashboard shows escalation status after T+24h (mocked scheduler)
4. PDF export in Hindi: Devanagari characters render correctly in downloaded PDF

16.4 No-Fetch Invariant Test (CI-blocking)

A dedicated test MUST be written and run in CI that:

1. Instruments all outbound HTTP calls in the application process

2. Submits a URL to the URL parsing endpoint
3. Asserts that zero outbound HTTP calls were made to the submitted URL or its resolved domain
4. This test MUST fail the CI pipeline if it detects any outbound HTTP call to a user-submitted URL

This test is the automated enforcement of NFI-01. It is not optional.

16.5 Security Testing

Pre-launch: OWASP Top 10 checklist review; manual penetration test on staging (at minimum SQL injection, IDOR on case IDs, CSRF, session fixation). Automated: dependency vulnerability scan in CI.

16.6 Accessibility Testing

axe-core (automated) in E2E suite. Manual screen-reader test before launch. Keyboard-navigation test for all critical flows.

16.7 Performance Testing

Lighthouse CI in CI/CD pipeline. Fail build if LCP > 3s or JS bundle > 200KB gzipped.

16.8 Load Testing

Before public launch: simulate 100 concurrent case submissions on staging. Target: no degradation in API p95 response times.

17. Phase 2 Forward Compatibility

Phase 2 introduces client-side perceptual hashing and a hash network. The following Phase 1 design decisions MUST preserve Phase 2 extension points without over-engineering them now.

P2-01 — Hash Module Interface The URL submission service is the point at which Phase 2 hashing plugs in. Phase 1 MUST leave a clearly named, no-op hook point in the URL submission flow (e.g., `await hashService.processIfEnabled(submittedUrl)`) that is a no-op in Phase 1. Phase 2 replaces this with the actual client-side hash flow. No hash schema, no hash logic, no pHash columns in Phase 1.

P2-02 — Platform Database Extensibility The `platforms` table MUST have a `supports_hash_api` boolean column (defaulting to `false`) and a `hash_api_endpoint_key` column (null). These are Phase 2 fields added in Phase 1 schema to avoid a migration at a busy time. No Phase 1 code reads these fields.

P2-03 — No Over-Design Phase 2 hash module, hash database table, hash network API client, and webhook receiver are NOT designed in this TRD. They will be specified in TRD v0.2 (Phase 2). Phase 1 engineers MUST NOT implement speculative hash infrastructure.

18. Deferred Decisions (from PRD §19)

These open questions from PRD §19 remain unresolved. They MUST be resolved before or during development. Resolution should be recorded as an amendment to this TRD.

ID	Question	Owner	Impact
D-01	Legal entity structure (Section 8 company, trust, or NGO)?	Founder	Affects credibility of notices; required before launch

ID	Question	Owner	Impact
D-02	Anonymous vs. registered submissions — allow anonymous submissions with no follow-up?	Product	Affects auth model; if yes, significant rework of OTP requirement
D-03	Languages at launch — Hindi + English only, or add a third?	Product	Affects i18n timeline; Bengali/Tamil add ~2 weeks
D-04	Supporter pathway — Day 1 or post-launch?	Product	If Day 1: \$FR-REG-08 and consent form upload must be implemented in Phase 1
D-05	Funding and development timeline — minimum 3–4 months funded development required	Founder	Blocks all other decisions
D-06	POCSO reporting protocol — what is Asmita's mandatory reporting obligation?	Legal Advisor	Must be resolved before production deployment; non-negotiable
D-07	GO database maintenance ownership — who owns monthly re-verification of platform contacts?	Ops	Must be assigned before launch; stale GO contacts make notices undeliverable
D-08	Non-response playbook — defined escalation chain when platform ignores notices for 72 hours	Legal + Product	Must be documented before launch; FR-ESC covers technical side only

Appendix A: Notice Template Reference (Abbreviated)

Full template content is stored in the database (`notice_templates` table). The following shows structure only for engineering reference:

Template A — Indian IT Rules 2021 Variables: `{platform_name}`, `{case_id}`, `{content_url}`, `{is_fir_filed}`, `{fir_details}` Fixed citations: IT Act 66E, IT Act 67A, BNS 77, IT Rules 2021 Rule 3(2)(b) Mandatory footer: Asmita contact email, website

Template B — International DMCA + Indian Law Variables: same as A, plus `{victim_authorization_reference}` Lead citation: DMCA Section 512 Secondary: IT Act 66E, 67A, BNS 77

Template C — Pornographic Platforms (DMCA Primary) Variables: same as B, plus `{platform_abuse_form_url}`, `{hosting_provider}` Escalation path included in body: registrar + CDN

All templates require legal advisor review and signature in `notice_templates.reviewed_by` before being set to active. A template without a legal advisor review timestamp MUST NOT be activated.

Appendix B: Platform Database Seed (Tier 1 — Pre-Launch Requirement)

Before launch, the Asmita team MUST research and verify the following contacts. This is a pre-launch task, not a post-launch improvement.

Platform	Routing Tier	Template Type	Contacts to Verify
Meta (Facebook/Instagram)	Tier 1 (API) + Tier 2 fallback	indian_it_rules	IT Rules GO email; NCII API access
YouTube (Google India)	Tier 1 (API) + Tier 2	indian_it_rules	IT Rules GO; Google Removal API
Twitter / X	Tier 2	indian_it_rules	Current IN GO email

Platform	Routing Tier	Template Type	Contacts to Verify
Telegram	Tier 2 / Tier 3	international_dmca	abuse@telegram.org; MeitY fallback
WhatsApp	Tier 2	indian_it_rules	IT Rules GO email
ShareChat	Tier 2	indian_it_rules	grievance@sharechat.com (verify)
Josh / Moj / MX TakaTak	Tier 2	indian_it_rules	Research required
Snapchat	Tier 3	international_dmca	DMCA form URL
Pornhub (Aylo)	Tier 3	pornographic_dmca	DMCA form URL
xVideos	Tier 3	pornographic_dmca	Abuse form URL
xHamster	Tier 3	pornographic_dmca	Abuse form URL
XNXX	Tier 3	pornographic_dmca	Abuse form URL
Google Search	Tier 1	indian_it_rules	removals.google.com API
Bing	Tier 3	international_dmca	Bing removal form URL

All entries must have `last_verified_at` set to the verification date and `verified_by` set to the team member who confirmed the contact. No placeholder contacts at launch.

TRD Owner: [Engineering Lead / CTO] Legal Review Required Before Templates Go Active: IFF or SFLC.in Last Updated: 2026-05-12 Derived from: PRD_Asmita.md v0.2 Next Review: When PRD is updated to v0.3 or Phase 2 scope is confirmed